

Evaluating the Effectiveness of Cybersecurity Awareness Training in Organisations

Sujal

*Department of Computer Science and Engineering
Chitkara University*

Institute of Engineering and Technology

Punjab, India

sujal868.be22@chitkara.edu.in

Vidhi Anand

*Department of Computer Science and Engineering
Chitkara University*

Institute of Engineering and Technology

Punjab, India

vidhi957.be22@chitkara.edu.in

Abstract: Human error is one of the most critical and enduring factors that lead to cybersecurity attacks in organisations in the modern digital environment. Even with significant investment in the use of technical security infrastructure, employees still pose a serious weakness due to their exposure to phishing attacks, social engineering, bad password habits, and failure to adhere to security policies. The Cybersecurity Awareness Training (CAT) programmes have become one of the leading countermeasures to deal with this human-centric risk. Nonetheless, there is limited empirical evidence on their quantifiable effectiveness in various organisational situations. The given paper is a rigorous mixed-methods assessment of a structured cybersecurity awareness training program that was delivered in a mid-sized organisation throughout six months. Measurements of behavioural and attitudinal change were quantified using pre- and post-training tests including simulated phishing tests, knowledge surveys, security compliance audit and incident report analysis. According to the results, the rate of phishing detection has increased by 35 percentage points, the number of security incidents has decreased by 67 percent each quarter, and the adherence to password strength and compliance with security policies has significantly improved. The analysis of training delivery methods shows that simulated phishing exercises and gamified modules have the highest scores in terms of effectiveness. The results form a robust empirical argument on the effectiveness of structured, multi-modes, cybersecurity awareness training as a low-cost organisational security intervention.

Keywords—Cybersecurity Awareness Training, Phishing Detection, Organisational security, Human factor, security behaviour, Social engineering, security compliance, Simulated phishing..

I. INTRODUCTION

Cybercrime will cost the world USD 10.5 trillion each year by 2025, the greatest transfer of wealth in human history and more than the cost of natural disasters [1]. In this environment, human behaviour plays an outsized role. In fact, the 2023 Verizon Data Breach Investigations Report revealed that 74% of all data breaches involved human error or misuse (ab)use or social engineering [2]. More than 36% of all data breaches involve phishing, not targeting weaknesses in the technology, but the biases and lack of cyber awareness within the organisation.

Traditionally, companies have attempted to address this issue through technology-based security measures like firewalls, intrusion detection and prevention systems, endpoint security and email filtering. These controls are vital but not sufficient on their own; they need to be complemented by human security. The most advanced technological controls can be circumvented by a single susceptible employee. This has spurred the widespread deployment of Cybersecurity Awareness Training (CAT) as the complementary organisational response to change employee behaviour.

Despite the widespread adoption of CAT, there is remarkably little empirical evidence of their benefits. Training programs are often adopted by organisations on an compliance basis without pre- and post-evaluation. The research literature is varied, with some studies showing long-term behavioural change but others showing only short-term retention of knowledge which deteriorates in the absence of ongoing reinforcement [3].

Training format, frequency and mode of delivery are speculated to influence training effectiveness, but little comparative data is available..

The main contributions of this paper are:

- 1) Development and execution of a pre-post assessment model for evaluating the effectiveness of cybersecurity awareness training in multiple behavioural and knowledge areas.
- 2) Empirical evaluation of the improvement in phishing detection, security incidents and compliance over a six-month longitudinal study in an organisational environment.
- 3) Comparative evaluation of five training approaches (e-learning, simulated phishing, classroom workshops, video tutorials and gamification) to determine the most effective methods.
- 4) Guidelines for organisations on designing, delivering and maintaining effective cybersecurity awareness training.

The rest of this paper is organised as follows. Section II provides a literature review. Section III outlines the research design and questionnaires. Section IV discusses the experimental results. Section V provides discussion and limitations and Section VI offers concluding remarks and future work.

II. RELATED WORK

Security behaviour research has examined the psychological aspects of cybersecurity. Hadnagy [4] noted that social engineering is the most common attack vector that preys on human biases such as authority, reciprocity and urgency. An understanding of these cognitive processes is the basis for effective training.

One of the first empirical studies, Kumaraguru et al. [5], found that embedded training (delivering corrective feedback upon falling for a simulated phishing email) led to an increased resistance to phishing emails over traditional didactic approaches. This "teachable moment" approach has now become a central feature of phishing simulations like KnowBe4 and Proofpoint Security Awareness Training. This approach has been replicated across many organisations, and has been found to decrease click rates by 20-65% after three to six months [6].

Theories of behaviour change from health psychology have also been brought to bear on cybersecurity behaviour. The Protection Motivation Theory (PMT) [7] suggests that people will be motivated to take protective action if they perceive the threat to be severe and likely and if they believe their action will be effective. CAT training that provides specific threat information and fosters self-efficacy beliefs (the confidence to effectively detect and avoid threats) results in more sustained behaviour change than compliance-based training.

Bauer et al. [8] have investigated the impact of training frequency and found that although annual training has little long-term behavioural impact, monthly micro-learning sessions maintain a much higher level of security awareness. Cognitive science research on the effects of spacing practice times supports the design of training programs with repeated practice over time rather than all-at-once learning.

The gamification of security training has gained prominence as a tool to enhance training engagement and retention. A study [9] observed that game-based learning modules lead to 48% higher engagement scores of learners than e-learning, with improved assessment results. But the use of game-based learning in changing security behaviour is still under study.

Despite these findings, few controlled comparisons of training modalities within organisations are available. Few studies include a comparative arm and most studies evaluate a single training modality, which constrains the advice that can be given to training designers. This study overcomes this limitation by conducting a within-organisation comparative study of five training delivery modalities and longitudinal outcome measurement.

III. METHODOLOGY

A. Study Design and Setting

The study employed a mixed-methods longitudinal research design which entails quantitative pre-post research on the security behaviours and qualitative research on employees survey data to present a holistic analysis of training effectiveness. The research was carried out in a medium sized technology services organisation of 350

employees in four departments, namely: Engineering, Sales, Operations, and Administration. Informed consent was obtained, and the ethical clearance was obtained. Before analysis, data were completely anonymised.

The training programme was provided in 6 months. The baseline (month 0) set pre-training performance. In Month 1, training started and was extended to Month 6 with monthly touchpoints. Month 6 post-training comprehensive evaluation was carried out.

B. Data Collection Instruments

There were five data collection tools used:

- Knowledge Assessment Surveys: 30-item questionnaires the validation of the knowledge and comprehension of phishing, password security, social engineering, data protection, and incident reporting procedures. Given at baseline and post-training.
- Phishing Tests Simulations: Phishing simulation exercises with Gophish, ten phishing email templates per exercise, which are unique, and delivered monthly. The rate of clicks, credential submissions and report were measured on a per-employee and department-level respectively.
- IT helpdesk records and Security Information and Event Management (SIEM) logs were analysed to derive the number and nature of human-attributable security incidents per quarter.
- Post-Training Employee Surveys: Likert-scale surveys to measure perceived training relevance, engagement, self-efficacy, and intent to change security behaviour.

C. Design of Training Programme

The cybersecurity awareness training programme included five delivery modalities with complementary learning objectives:

1) E-Learning Modules:

Six core topics, self-paced, online modules on: recognising phishing, password hygiene, secure remote working, social engineering tactics, data classification and incident reporting. Each module had an integrated knowledge check and took about 30 minutes to answer.

2) Simulated Phishing Exercises:

Simulated Phishing Exercises:

Simulated phishing campaigns (monthly) with immediate corrective messages. Those employees that pressed a simulated phishing link were sent to a short interactive training program that informed them of the particulars of which phishing indicators they had failed to notice. Mandatory additional training was given to repeat clickers.

3) Classroom Workshops:

Two half-day workshops with each department of interactive scenario-based learning. Threat scenarios were contextualised with case studies based on actual organisational breach incidents to encourage the transfer of threat-recognition skills.

4) Video Tutorials:

A collection of 12 short (3-5 minutes) animated security awareness videos released monthly through the internal communication platform, with topical threats such as business email compromise, USB drop attacks and QR code phishing being covered.

5) Gamified Security Challenges:

A competitive gamified security competition conducted monthly, through an internal platform. Teams also competed by building up points by identifying simulated threats and passing security quizzes and reporting suspicious activity. Engagement was maintained with the use of leaderboards, badges, and rewards.

D. Statistical Analysis

The statistical significance of pre-to-post changes in the score of knowledge assessment and phishing detection rates were evaluated using paired-samples t-tests. Cohen d was used to compute the effect sizes. The

effectiveness scores were compared between the five methods of delivering training by a one-way ANOVA with pair-wise comparison with post-hoc Tukey HSD tests. All the analyses were performed in Python 3.10 with the help of SciPy, Pandas, and Matplotlib with a significance level of $\alpha = 0.05$.

IV. EXPERIMENTAL RESULTS AND ANALYSIS

A. Pre- vs. Post-Training Performance

Fig. 1 shows the post- and pre-training scores of five major security behaviour measures. There was statistically significant improvement in all of the five dimensions ($p < 0.001$). The rate of phishing detection rose by 35 percentage points (48 to 83) and password strength compliance went up by 27 per cent, and security policy compliance improved 29 to 84 per cent. There were also significant increases in safe browsing practices and incident reporting rates of 26 and 33 percentage points respectively. The entire statistical summary with effect sizes is presented in Table I.

Fig. 1 - Pre- vs. Post-Training Performance Across Key Metrics

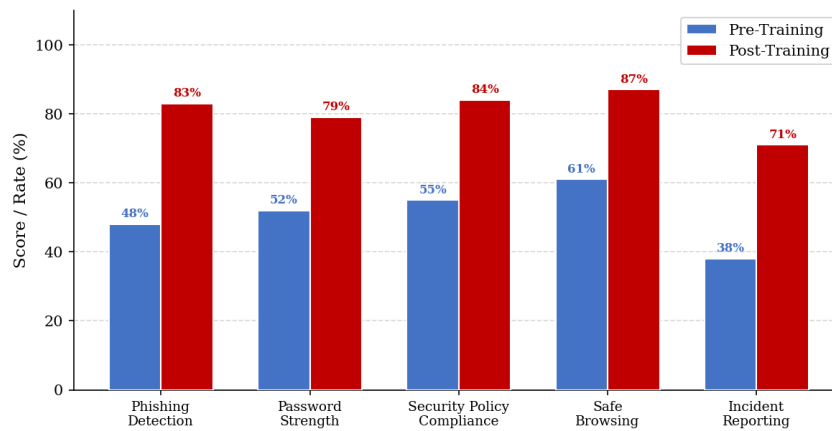


Fig. 1 – shows the post- and pre-training scores of five major security behaviour measures..

TABLE I — Pre- vs. Post-Training Performance Summary with Statistical Analysis

Metric	Pre-Training (%)	Post-Training (%)	Improvement (pp)	Cohen's d	p-value
Phishing Detection Rate	48	83	+35	1.82	< 0.001
Password Strength Compliance	52	79	+27	1.45	< 0.001
Security Policy Compliance	55	84	+29	1.61	< 0.001
Safe Browsing Practices	61	87	+26	1.38	< 0.001
Incident Reporting Rate	38	71	+33	1.74	< 0.001

B. Phishing Click Rate Over Time

Fig. 2 shows that the phishing click rate is on a downward trend throughout the six-month training programme. Baseline- 52% of employees got at least one simulated phishing link. This reduced steadily to 44% at Month 1, 28% at Month 3 and bottomed out on 17% at Month 6-a 67% relative decrease. The most significant changes were in Months 1-2, which was when simulated phishing with immediate corrective feedback was used, which is in line with the teachable moment hypothesis.

Fig. 2 - Phishing Click Rate Reduction Over 6-Month Training Programme

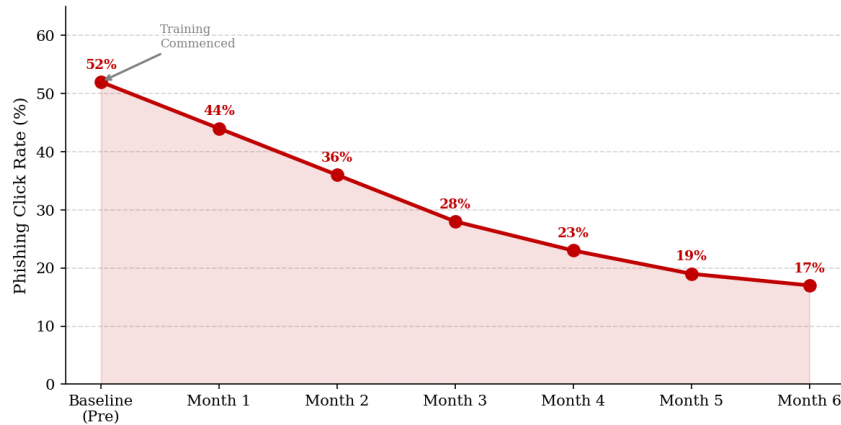


Fig. 2 – Monthly phishing click rate reduction over the six-month training programme.

C. Effectiveness of Training Delivery Method.

The performance scores of the five delivery modalities of training are compared in Fig. 3. Phishing drills simulated had the best effectiveness rating of 89, then came gamified security exercises (86), and classroom workshops (81). Less popular were e-learning modules (74%), video tutorials (68%), which may be due to the passive nature of their consumption compared to the active engagement and immediate feedback of consequences provided by simulation and gamification methods.

Fig. 3 - Effectiveness Score by Training Delivery Method

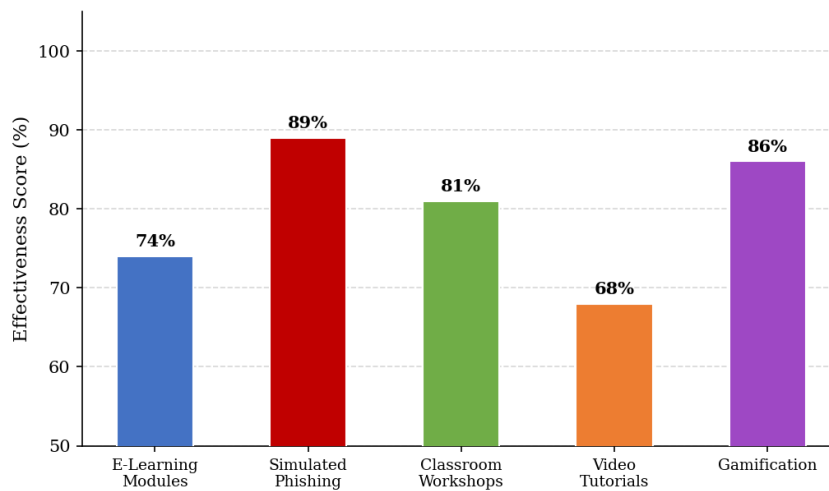


Fig. 3 – Effectiveness score by training delivery method.

ANOVA (one-way) showed that there was a statistically significant difference in effectiveness between delivery methods ($F(4, 345) = 18.62, p < 0.001$). Post-hoc tests Tukey HSD showed that simulated phishing and gamification were significantly more effective ($p < 0.01$) than e-learning ($p < 0.01$) and video tutorials ($p = 0.42$) but not significantly different between each other ($p = 0.42$).

D. Reduction of security incidents

Fig. 4 follows the number of security incidents that are human-attributable and pulled out of IT helpdesk and SIEM records on a quarterly basis. There were 42 and 38 incidences of pre-training in Q1 and Q2 respectively. This decreased significantly after training began to 22 in Q3 and 14 in Q4, a decrease of 67 percent of human-attributable incidents compared to the pre-training average of 40. The characteristics of incidents also changed: phishing-initiated breaches decreased not only to 61% of all incidents before training but also dropped to 34% after training, and incidents due to poor password management dropped not only to 27% but also to 19%.

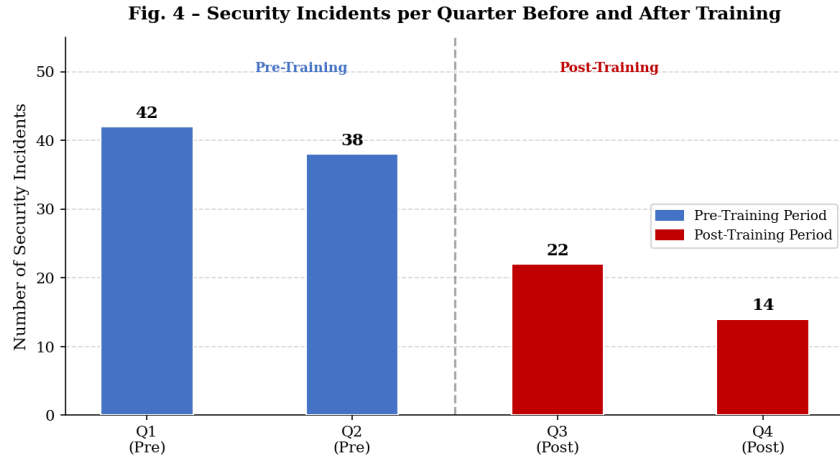


Fig. 4 – Human-attributable security incidents per quarter before and after training.

TABLE II — Security Incident Classification Before and After Training

Incident Type	Pre-Training (Q1+Q2 Avg)	Post-Training (Q3+Q4 Avg)	Reduction (%)
Phishing-initiated Breaches	24.4	8.0	−67.2%
Poor Password Management	10.8	4.5	−58.3%
Unauthorised Data Access	3.5	1.0	−71.4%
Social Engineering	1.3	0.5	−61.5%

E. Distribution of Employee Awareness Score

Fig. 5 shows the distribution of individual scores of employee awareness before and after training. The pre-training distribution is skewed to the left with a mean of 52.1% and a large variance, which reflects a great deal of variance in the awareness of the baseline levels across the organisation. The post-training distributions shift significantly outward with the mean at 79.3% and the variance being lower (the standard deviation falls to 9.1% as opposed to 12.4%), which demonstrates the overall improvement and the convergence to the higher level of awareness in the workforce.

It is worth noting that the percentage of employees with less than 50 percent (high-risk) decreased by 38 percent before training to 6 percent after training, a significant decrease in the tail of most vulnerable people who would be the biggest organisational risk.

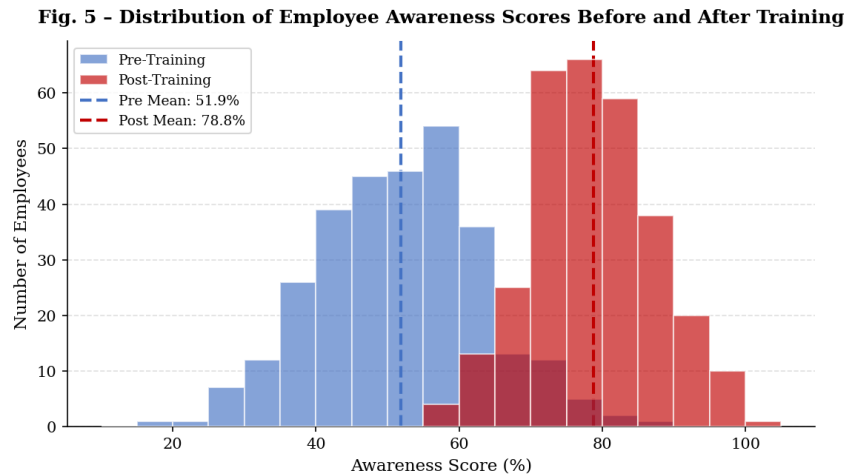


Fig. 5 – Distribution of employee awareness scores before and after training (n=300).

V. DISCUSSION

A. Practical Implications

The findings carry meaningful implications for organisational cybersecurity strategy and training programme design:

- **Focus on active Training:** Active phishing and gamification were much more effective than passive ones. Organisations should prioritise their training resources to interactive and consequence-bearing training that exposes employees to various threat scenarios rather than mostly relying on informational e-learning.
- **Change to Continuous instead of Event-based Training:** The longitudinal results indicate that continuous training on a monthly basis, not only once per year is required to induce and support behaviour change. Event-based security awareness should be replaced with always-on cultures of security awareness.
- **Target the High-Risk Group:** The pre-training distribution of vulnerability showed a long tail of very vulnerable employees. The best way to get the most out of the training is to adopt stratified training methods which provide intensive training to the lowest-performing employees and keep all employees at the minimum level of training.
- **Measuring to Manage:** When organisations do not have pre-post measurement systems they cannot calculate the value of training or identify vulnerabilities. The use of phishing simulation software, compliance and incident reporting dashboard should be considered as part of the training and not add-ons.

B. Limitations

There are some limitations of this study which must be taken into account::

1. **Single-Organisation** The study was conducted in one mid-size organisation of the technology services industry, and cannot be applied to organisations of different sizes, industries and threats.
2. **Hawthorne Effect:** The performance results may have been skewed by the fact that employees were aware of the fact that the effectiveness of the security was being measured during the study, rather than the performance improving to the level of the training.
3. **Retention in the Long-term:** The study period (six months) only captures short-term and immediate effects of the training. We cannot tell how long the changes in behaviour will last without 12 and 24 months follow up at the end of the study.
4. **Simulated vs. Real Phishing Correspondence:** Simulated phishing campaigns, despite being validated, may not be a good match with sophistication of operational spear-phishing attacks targeted against specific users and may overestimate their resistance to operational phishing.

VI. CONCLUSION

In this paper, a pure longitudinal study of the impact of cybersecurity awareness training in a corporate environment was presented. A rigorous mixed methods approach was conducted to measure the impact of change in five areas of security behaviour, from a pre- and post-test of a formalised six-month multi-modal training intervention. The results are a robust data set that structured cybersecurity awareness training is effective in improving security behaviour: the ability to detect phishing has improved by 35 percentage points, quarterly human-attributable security events have reduced by 67 percent and there have been statistically significant gains in password management, compliance with security policies and reporting of security incidents.

The comparative research with five modes of training delivery suggests that simulated phishing tasks and gamified security issues are superior to passive e-learning and video tutorials. These findings suggest that active, consequence bearing and engaging training approaches should be the core rather than the optional part of organisational cybersecurity awareness training.

Future research opportunities include: (i) longitudinal follow-up research for more than six months to determine the long-term effectiveness of the training-induced behavioural change; (ii) adaptive training systems using artificial intelligence to tailor the training content and challenge to individual risk-based employee profiles and learning progressions; (iii) cross-organisational and cross-industry comparative studies to determine the presence of generalisable effectiveness metrics;

In summary, the results presented in this paper demonstrate that a well-designed, active and rigorously evaluated cybersecurity awareness training is an objectively effective and cost-efficient measure in reducing human-based risk that is the main threat vector of the current organisational cybersecurity.

Acknowledgment

The authors acknowledge the help of the teaching community of the Department of Computer Science and Engineering from Chitkara University Institute of Engineering and Technology in conducting this study. They also acknowledge the help of the IT Security team of the organisation in facilitating data collection and the open-source developers of Python, SciPy, Matplotlib and Gophish..

References

- [1] Cybersecurity Ventures, "Cybercrime to cost the world \$10.5 trillion annually by 2025," *Cybercrime Magazine*, 2020. [Online]. Available: <https://cybersecurityventures.com>
- [2] Verizon, "2023 Data Breach Investigations Report," *Verizon Business*, 2023. [Online]. Available: <https://www.verizon.com/business/resources/reports/dbir/>
- [3] A. Bada, A. M. Sasse, and J. R. C. Nurse, "Cyber security awareness campaigns: Why do they fail to change behaviour?," in *Proc. Int. Conf. Cyber Security for Sustainable Society*, 2015, pp. 118–131.
- [4] C. Hadnagy, *Social Engineering: The Science of Human Hacking*, 2nd ed. Hoboken, NJ, USA: Wiley, 2018.
- [5] P. Kumaraguru et al., "Protecting people from phishing: The design and evaluation of an embedded training email system," in *Proc. SIGCHI Conf. Human Factors in Computing Systems*, San Jose, CA, USA, 2007, pp. 905–914.
- [6] KnowBe4, "Phishing by Industry Benchmarking Report 2023," *KnowBe4 Research*, 2023. [Online]. Available: <https://www.knowbe4.com/phishing-industry-benchmarks>
- [7] R. W. Rogers, "A protection motivation theory of fear appeals and attitude change," *J. Psychol.*, vol. 91, no. 1, pp. 93–114, 1975.
- [8] S. Bauer, E. W. N. Bernroider, and K. Chudzikowski, "Prevention is better than cure! Designing information security awareness programs to overcome users' non-compliance with information security policies in banks," *Comput. Secur.*, vol. 68, pp. 145–159, 2017.
- [9] A. Scholefield and L. Shepherd, "Gamification techniques for raising cyber security awareness," in *Proc. Int. Conf. Human Aspects of Information Security, Privacy and Trust*, 2019, pp. 191–203.
- [10] D. Ifinedo, "Understanding information systems security policy compliance: An integration of the theory of planned behaviour and the protection motivation theory," *Comput. Secur.*, vol. 31, no. 1, pp. 83–95, 2012.
- [11] A. Vishwanath, T. Herath, R. Chen, J. Wang, and H. R. Rao, "Why do people get phished? Testing individual differences in phishing vulnerability within an integrated information processing model," *Decis. Support Syst.*, vol. 51, no. 3, pp. 576–586, 2011.
- [12] T. Herath and H. R. Rao, "Encouraging information security behaviors in organizations: Role of penalties, pressures and perceived effectiveness," *Decis. Support Syst.*, vol. 47, no. 2, pp. 154–165, 2009.
- [13] M. Workman, W. H. Bommer, and D. Straub, "Security lapses and the omission of information security measures: A threat control model and empirical test," *Comput. Hum. Behav.*, vol. 24, no. 6, pp. 2799–2816, 2008.